



# Security Architecture & Information Security

Financial Management System for Construction & FM Projects

---

|                        |                                  |
|------------------------|----------------------------------|
| <b>Version:</b>        | 1.0                              |
| <b>Date:</b>           | 09 April 2026                    |
| <b>Author:</b>         | Bar Pessa — Logi Group           |
| <b>Classification:</b> | Confidential — Internal Use Only |
| <b>Status:</b>         | Pending InfoSec Approval         |

# Table of Contents

- 1. System Overview
- 2. Technical Architecture
- 3. Authentication & Authorization
- 4. Data Storage & Encryption
- 5. Network & Communication Security
- 6. Access Control Matrix
- 7. Google Cloud Platform (GCP) Services
- 8. AI & Machine Learning Components
- 9. Risk Assessment & Mitigation
- 10. Regulatory Compliance
- 11. Recommendations for Approval

# 1. System Overview

Logfi is an internal financial management system built for Logi Group / Manrav IFM. The system manages the financial aspects of construction, maintenance and facility management (FM) projects — including P&L reports, cash flow analysis, subcontractor management, payment terms, and risk analysis.

## Data Types

- Project financials: revenue, expenses, payment terms, P&L, cash flow
- Supplier data: name, contact details, contract amounts, payment terms
- Salary costs: monthly amounts per project (not individual employee salaries)
- Financial reports: P&L, cash flow, risk scoring, variance analysis
- User accounts: name, email, role, authentication credentials

## System Users

| Role               | Count | Access Level                          |
|--------------------|-------|---------------------------------------|
| System Admin (CEO) | 1     | Full access including user management |
| Economist          | 1     | Full access except user management    |
| Viewer             | 1-3   | Read-only access to all data          |
| Project Manager    | 3     | Read-only access to own projects only |

## 2. Technical Architecture

### System Components

| Component      | Technology              | Purpose                       |
|----------------|-------------------------|-------------------------------|
| Frontend       | Vue 3 + Tailwind CSS    | Single Page Application (SPA) |
| Backend        | FastAPI (Python)        | REST API + business logic     |
| Database       | Google Firestore        | NoSQL document database       |
| Authentication | Firebase Authentication | User auth + 2FA (TOTP)        |
| Hosting        | GCP Cloud Run           | Serverless container platform |
| AI Chatbot     | Google Gemini API       | Financial analysis assistant  |

### Data Flow

Browser (Vue SPA) --[HTTPS]--> Cloud Run (FastAPI) --[gRPC]--> Firestore  
Browser --[HTTPS]--> Firebase Auth --[JWT token]--> Cloud Run (verify)  
Cloud Run --[HTTPS]--> Gemini API (summary data only, no PII)

## 3. Authentication & Authorization

### Authentication

- Firebase Authentication with email + password
- Two-Factor Authentication (2FA) via Google Authenticator (TOTP)
- JWT tokens issued by Firebase, verified server-side with Firebase Admin SDK
- Token expiry: 60 minutes, auto-refreshed by Firebase SDK
- Passwords stored exclusively in Firebase (hashed, never in application code)
- Clock skew tolerance: 30 seconds for token verification

### Authorization

- 4 permission levels: admin, economist, viewer, project\_manager
- Every API request requires valid JWT token — verified server-side
- Project managers can only access projects assigned to them (linked\_manager)
- Authorization enforced on backend — cannot be bypassed from client
- CORS restricted to application domain only

## 4. Data Storage & Encryption

- All data stored in Google Firestore (NoSQL)
- Encryption at rest: AES-256, managed by Google (default)
- No direct Firestore access from browser — all access through backend API
- Service Account with minimal permissions (principle of least privilege)
- Service Account keys excluded from Git (.gitignore)
- Sensitive credentials (API keys, passwords) stored in environment variables

### Data Classification

| Data Type          | Sensitivity | Storage         | Protection                          |
|--------------------|-------------|-----------------|-------------------------------------|
| Project financials | High        | Firestore       | AES-256 at rest + HTTPS             |
| Supplier details   | Medium      | Firestore       | AES-256 at rest + HTTPS             |
| Salary costs       | High        | Firestore       | AES-256 at rest + role-based access |
| User passwords     | Critical    | Firebase Auth   | bcrypt hash (never stored in app)   |
| API keys           | Critical    | Env vars / .env | gitignored, GCP Secret Manager      |

## 5. Network & Communication Security

- All traffic encrypted via HTTPS/TLS — no HTTP endpoints
- Cloud Run provides automatic SSL certificate (managed by Google)
- CORS policy restricts API access to authorized domain only
- Firebase Auth tokens transmitted in Authorization: Bearer header
- No sensitive data stored in cookies or localStorage (except Firebase session)
- No external API receives personally identifiable information (PII)

## 6. Access Control Matrix

| Action            | Admin     | Economist   | Viewer      | Project Mgr  |
|-------------------|-----------|-------------|-------------|--------------|
| View all projects | Yes       | Yes         | Yes         | Own only     |
| Create project    | Yes       | Yes         | No          | No           |
| Edit project      | Yes       | Yes         | No          | No           |
| Update actuals    | Yes       | Yes         | No          | Own only     |
| Manage users      | Yes       | No          | No          | No           |
| AI Chatbot        | All data  | All data    | Read-only   | Own projects |
| Export PDF        | Yes       | Yes         | Yes         | Own only     |
| View dashboard    | Executive | Operational | Operational | My Projects  |

## 7. Google Cloud Platform (GCP) Services

### Services Used

| Service       | Purpose                         | Region      |
|---------------|---------------------------------|-------------|
| Cloud Run     | Application server (serverless) | us-central1 |
| Firestore     | Document database               | us-east1    |
| Firebase Auth | User authentication + 2FA       | Global      |
| Cloud Build   | Docker image builds             | us-central1 |

### GCP Security Controls

- GCP Project ID: minlog-491211
- Billing account with budget alerts configured
- IAM: Service Account with minimal permissions only
- No public access to Firestore — backend Service Account only
- Cloud Run: Application-level authentication (Firebase JWT)
- Docker images built via Cloud Build (no local builds in production)

### GCP Certifications

- SOC 1, SOC 2, SOC 3
- ISO 27001 — Information Security Management
- ISO 27017 — Cloud Security
- ISO 27018 — PII Protection in Cloud

## 8. AI & Machine Learning Components

The system includes a financial analysis chatbot powered by Google Gemini API.

### AI Data Policy

- Chatbot receives only project summaries (name, revenue, expenses, margin)
- No salary data, supplier PII, or personal information sent to AI
- Gemini API: data not used for model training (per Google policy)
- Planned: migration to Vertex AI (data stays within GCP project)
- Financial calculations (What-If, Risk Score) run in Python — no AI involved
- AI responses are advisory only — no automated financial decisions

## 9. Risk Assessment & Mitigation

| Risk                | Severity | Mitigation                                     |
|---------------------|----------|------------------------------------------------|
| Password breach     | Critical | Firebase Auth + 2FA + bcrypt                   |
| Unauthorized access | High     | JWT + RBAC + server-side enforcement           |
| Data leak           | High     | Encryption at rest + HTTPS + CORS              |
| API key exposure    | Medium   | .env + .gitignore + Secret Manager             |
| AI hallucination    | Low      | Grounded prompts + temperature 0.25            |
| DDoS attack         | Low      | Cloud Run auto-scaling + Google infra          |
| SQL injection       | None     | Firestore NoSQL (no SQL queries)               |
| XSS                 | Low      | Vue.js auto-escaping + no v-html on user input |

## 10. Regulatory Compliance

Google Cloud Platform meets the following standards:

- SOC 1, SOC 2, SOC 3 — Service Organization Controls
- ISO 27001 — Information Security Management System
- ISO 27017 — Cloud-Specific Information Security
- ISO 27018 — Protection of PII in Public Cloud
- GDPR compliance available (Data Processing Agreement)
- Google Cloud DPA available upon request



## 11. Recommendations for Approval

The following steps are recommended before production deployment:

- 1. Architecture review — review of this document by Information Security Officer
- 2. Password policy — define minimum length, complexity, expiration
- 3. Mandatory 2FA — enforce for all users (currently optional)
- 4. GCP budget alerts — configure alerts for unexpected spending
- 5. Audit logging — track sensitive operations (user creation, data exports)
- 6. Code review — verify no credential exposure in source code
- 7. Penetration test — optional, recommended for production
- 8. Backup & recovery — define RPO/RTO and test procedures
- 9. Google DPA — sign Data Processing Agreement with Google
- 10. Final approval — Information Security Officer sign-off

### Contact

For questions or clarifications:

- Bar Pesso — System Developer
- bar@logigroup.co

Information Security Officer Signature: \_\_\_\_\_

Date: \_\_\_\_\_